

Slide 1: The Cold Open (5:00 Total)

0:00 – 1:30 | The Mundane Morning

"It's 8:15 AM on a Tuesday in April. **Most of** the world is still waking up, but at a **regional energy** utility right here in Pennsylvania, **an engineer**—we'll call him Dave—is just settling in. **He's got** his first cup of coffee, **the sun** is hitting his desk, **and he's** doing exactly what we all do: **he's clearing** the overnight noise from his inbox.

Dave isn't looking for a fight. **He's not** looking for a 'threat.' **He's just** looking for a way **to get** through his Tuesday. **And that's** when he sees it. **An Outlook** notification. **It's marked** 'Urgent,' and the subject line reads: *'Harrisburg Infrastructure Assessment – Action Required.'* **Now**, Dave doesn't hesitate. **Why would** he? **He was** working on the Harrisburg project yesterday. **The email** is from a vendor he's known for five years. **Everything about** this feels like a normal part of a productive morning."

1:30 – 3:00 | The "Slow-Motion" Click

"**Dave clicks** the link. **He doesn't** get a 'Warning: Malicious Site' banner. **His browser** doesn't stutter. **He's taken** to a SharePoint login page that **is... perfect**. The branding, the fonts, the **'Privacy' links** at the bottom—it's all there.

He types his username. **He types** his password. **He's not** being 'tricked' by a fake site; **he is** looking at a live-stream of the real Microsoft. **And then**, the push notification hits his phone. *Ping.* **It's muscle** memory. **Dave doesn't** even look away from his monitor; **he just** reaches down, **taps 'Approve,'** and goes back to his coffee. **The document** opens—a 40-page PDF on infrastructure. **Dave spends** ten minutes reviewing it, **closes the** tab, **and moves** on to his next task. **In his mind**, he just had a successful start to his day."

3:00 – 4:15 | The Forensic Reveal & The Metaphor

"But while Dave is reading that PDF, **something is** happening in the memory of a proxy server. **That proxy** didn't just 'pass him through.' **It cloned** him. **By 9:30** AM, Dave still has his password, **but the** attacker has Dave's **identity**.

This is what I call the **'Invisible Valet.'** **Think about** how a valet works. **He doesn't** want your keys; **he wants** your car. **He stands** between you and the restaurant. **You hand** him your car, **he drives** it to the real valet, **gets the** real claim ticket, **and hands** it back to you. **You walk** into dinner **thinking** your car is safe. **Meanwhile,** the 'Invisible Valet' has already made a copy of **your** 'All-Access' pass and is **driving your** car out of the lot. **By the** time you finish dessert, **the car**—and everything in it—is gone."

4:15 – 5:00 | The Authority Bridge

"I'm Joel Prentice. I'm a Cybersecurity Engineer, and I **spend my** days looking **at the** gaps between our **'Padlocks'** and our reality.

Today, we are going to go under the hood of the 'Invisible Valet.' **We aren't** just going to talk about 'phishing.' **We are** going to dismantle the engine of the proxy, **packet by** packet, **and I'm** going to show you why in 2026, **the 'Same** Watering Holes' we use every day—**SharePoint,** Teams, and **Outlook**—have been turned into the perfect delivery systems **for a** new breed of lure.

5:00 – 5:30 | [Transition]:

"So, Dave's car is gone. **His identity** is cloned. **But how?** It's not because **our encryption** is broken. **It's because** our protocols have a **massive,** structural blind spot."

Slide2.

5:30 – 7:00 | The Transition: The Protocol Blind Spot

"So, Dave's car is gone. His identity is cloned. But how? It's not because our encryption is broken. It's because our protocols have a massive, structural blind spot. We've spent a decade telling our boards that MFA is the finish line—that if we just get to 100% enrollment, the game is over. But in 2026, we have to admit that compliance is just the floor. We are building massive security stacks on top of a foundation that is fundamentally 'context-blind.' Dave did everything we taught him to do, but the physics of the connection were rigged against him from the start."

7:00 – 8:30 | The \$20 Bill & The Hunter's Prize

"At the heart of this is how we handle identity. Most MFA we use—Push, SMS, or those 6-digit codes—ends with the server handing the user a Bearer Token. I want you to think of this like a \$20 bill. If I drop this bill in the hallway here at the PA Farm Show complex and you pick it up, it's yours. The guy selling coffee doesn't care who I am; he just cares that you're holding the cash.

In a Microsoft environment, the proxy is hunting for one specific piece of 'digital cash': the ESTSAUTHPERSISTENT cookie. This isn't just a random string; it's a signed blob that tells the cloud: 'This user has already proven they have the password and passed the MFA gate.' To an attacker, this cookie is worth more than the password. Because it isn't 'Sender-Constrained,' the attacker doesn't need to 'hack' anything—they just have to 'bear' the token. They pluck it out of the air in Pennsylvania and spend it in a data center halfway across the world. To the server, that's not a hack; that's just a guy with a twenty."

8:30 – 9:30 | The Two-Channel Forensic Gap

"**Now, why** didn't Dave's phone warn him? It's **the gap** between the Front and Back channels. **Dave lives** in the 'Front-Channel'—the browser. **But the** real 'handshake' happens in the '**Back-Channel**' between the server **and the** Identity Provider. **When that** push notification hit Dave's phone at **8:15 AM**, it asked: 'Are you trying to sign in?' **It's a** simple binary question. **It didn't** mention the proxy. **It didn't** mention that the request was **routed** through a **malicious** middleman. **The phone** has zero cryptographic **proof** of the **Origin URL**. We **are asking** our employees to make **high-stakes forensic** decisions based on a 'Yes/No' button **that is** functionally blind to the network metadata."

9:30 – 11:00 | The Persistence Trap & The Resident Proxy

"**And then** we have the Persistence Trap. **We've all** set those 14-day session windows **because** we don't want to get yelled at about 'MFA Fatigue.' **Attackers** love our convenience. **You** might think your 'Impossible Travel' logic would catch this, **but** the adversary has evolved. **They** aren't 'spending' that **digital cash** from a known-bad data center. **They** are using **Residential Proxy Networks**, **routing** that stolen cookie through a **hijacked** home router in a **neighborhood** three miles away from your office. **To** your logs, it doesn't look like an attack. **It just** looks like Dave decided to **check his email** from a Starbucks down the street. **Dave's** 'one-second' mistake becomes the attacker's 'month-long' residency."

"**Think about** the math of that. **We spend** millions on EDR to catch a **process** that runs for three seconds, **but we're** willing to let a stolen session **cookie** live for **1,209,600 seconds**. That **is a massive** asymmetry. **If you're** a Global Admin, **ask yourself**: 'Is my convenience **worth that** level of residency?' **If the answer** is no, **your 'Day 1'** plan just got a lot **more urgent**."

11:00 – 11:30 | The Closing Hand-off [Pause. Scan the room.]

"If our foundation is this shaky, we have to ask: how does the adversary actually **set up** the heist? How do they build a **machine** that can live-edit **Dave's** reality without him **seeing** a single glitch? To understand that, we have to **go under** the hood of the engine itself."

Slide 3.

11:30 – 13:00 | The Myth vs. The Reality

"When people hear 'phishing site,' they usually picture a static, fake page hosted on a **shady** server. They think if they look closely enough at the font or the logo, they'll spot the fake. But tools like **Evilginx** have changed the game. This isn't a 'copy' of Microsoft; it's a surgical, live-streamed relay. It isn't hosting anything. It's sitting in the middle, acting as a **translator** between Dave and the **real** Microsoft servers. If Microsoft changes their **background** image for a holiday at 2:00 PM, the **phishing** site changes at 2:00:01 PM. It is a perfect, real-time reflection."

13:00 – 15:00 | The Search & Replace Machine

"So how does it keep Dave from noticing he's on a different domain? It uses what I call the '**Search and Replace**' engine, powered by the **NGINX sub_filter** module. As the real data packets fly from Microsoft toward Dave's browser, the proxy catches them in mid-air. It scans the code for every mention of the real domain—**login.microsoft.com**—and live-edits it to point back to the proxy's domain. It's rewriting the fabric of the session on the fly. When Dave clicks 'Sign In,' the proxy catches that request, strips out Dave's info, forwards it to the real Microsoft, and then catches Microsoft's response to continue the lie. It's a high-speed game of 'Keep Away' where the user never sees the ball."

15:00 – 16:30 | Stripping the Armor (The Security Header Bypass)

"But wait—modern browsers have armor, right? **We** have **Content Security Policy (CSP)** and **X-Frame-Options** specifically **designed to** stop this. **This** is where the proxy gets **surgical**. As those security **headers fly** through the proxy, **it doesn't** try to bypass them; it just **deletes them**. It **identifies** the instructions that tell **the browser** 'Only trust Microsoft' and **simply strips** them out **of the** packet. **By the** time that data reaches Dave's laptop, **the browser** is functionally blind. **It's not** that the browser failed; **it's that** the instructions on how to protect itself **were stolen** before they could be read."

16:30 – 18:00 | The Termination Point & The Plaintext Prize

"**Here is** the most critical technical point: **the proxy** is the **TLS Termination Point**. **We've spent** years telling people 'Look for the padlock,' **but that** padlock only means the **tunnel is** encrypted. **In this attack**, there are **two** tunnels: **one from** Dave to the Proxy, **and one** from the **Proxy to** Microsoft. **Because** the proxy owns the keys to both, **it is** the only place in the world **where** that traffic is decrypted. **For a** fraction of a **millisecond** inside the proxy's RAM, **Dave's** password and **that ESTSAUTHPERSISTENT** cookie **exist in plaintext**. The **attacker** isn't 'cracking' encryption; **they are** just a legitimate end-point of a **hijacked conversation**."

18:00 - 18:30 | Transition

"**So, we** have this perfect machine. **It can** live-edit Dave's reality, **it can** strip his defenses, **and it** can sit in the middle of a '**secure**' **encrypted** tunnel while reading **his secrets** in plaintext.

[Step toward the center of the stage. Pause for 3 seconds.]

But here's the problem for the attacker: **A machine** that loud—a **machine** that is literally **tearing apart** packets and **rebuilding** them—should be easy

to find. **It should** be screaming 'malicious' to every **automated** scanner and threat **intel feed** on the planet. **[Click to Slide 4]**

Slide 4:

18:30 – 20:00 | The Identity-Aware Evasion

"By now, you're probably thinking: *'If this proxy is so loud—if it's stripping headers and editing traffic—why isn't my multi-billion dollar security cloud catching it?'* **It's because** the adversary has built a bouncer at the door. **They know** we're looking for them. **They have** a list of every IP address belonging to Microsoft, Google, **and every** major security vendor in this room. **If your** automated sandbox tries to visit the site, **the bouncer** executes a 'Silent Fail.' **It shows** a 404, or it redirects to the real Google. **To your SOC, the link** looks dead. **But the second** a real human from a **Pennsylvania IP** address clicks that link? **The door** opens wide."

20:00 – 22:00 | The Digital Accent (JA4 Fingerprinting)

"But they go deeper than just IP filtering. **They look** at your Digital Accent. **Every browser**—and every bot—**leaves a** unique signature during the TLS handshake. **We used** to use JA3, but the gold standard now is JA4.

[Point to the JA4 diagram]

Security scanners have very 'robotic' accents. **They use** specific cipher suites **in a** specific order that no human on a **standard** Chrome browser **would** ever use. **The proxy** bouncer inspects this signature **before a** single byte of the webpage is even served. **If the** fingerprint doesn't look **like a** real person on a real device, **the trap** stays hidden. **We are** fighting **an enemy** that can tell the difference between a forensic tool **and a** victim in a **fraction** of a second."

22:00 – 24:00 | Behavioral Gating: The Humanity Test

"Even if you get past the IP filter **and the** fingerprinting, **you hit the Humanity Test**. Modern proxies use Behavioral **Gating**. When **the page** first loads, **the 'Sign-In'** form isn't even in the code. **The script** is sitting there, waiting. **It's looking** for non-linear mouse movement. **It's looking** for a window resize. **It's looking** for a scroll.

If a sandbox takes a screenshot at 'Time Zero' **to analyze the page**, it just sees a **blank white screen**. Because the bot **doesn't 'move'** like a person, **the phishing** logic never triggers. **The bouncer** only hands over the keys **to the kingdom** when it's convinced **there's a heartbeat** on the other end **of the wire**."

"I want to highlight a trap for your SOC **teams here**. How many times has a **user** reported a link, **your analyst** clicks it in a sandbox, **sees a blank white page**, **and closes** the ticket as 'False Positive' or '**Broken Link**'? **That is exactly what the bouncer wants**. We have to train our analysts **that a '404'** or a 'Blank Page' **on a reported phish** isn't **a sign** of safety—it's **a sign** that the adversary **recognized** your forensic signature **and went dark**."

24:00 – 25:30 | Laundering the IP: Residential Proxies

"And finally, they've solved the 'Bad Reputation' problem. **They don't** host these from AWS or DigitalOcean anymore. **They use** Residential Proxy Networks. **When that** proxy reaches out to your Identity Provider **to steal** Dave's session, **it isn't** coming from a data center in Russia. **It's coming** from a hijacked home router **in a** neighborhood three miles from your office.

To your 'Impossible Travel' alerts, **this looks** perfectly normal. **The bouncer** hasn't just checked the ID; **he's ensured** the attacker is wearing **the same** 'local' uniform as your employees. **So the** bouncer is guarding **the door**, and **the proxy** is invisible. **Now, how** do we actually get the user **to walk** through it? **Let's talk** about the move to the pocket."

25:00 - 26:00 Transition to Slide 5

"So, the bouncer is at the door, **the proxy** is invisible, **and the** trap is perfectly set. **But a** trap is useless **if no** one walks into it. **The** adversary's

biggest challenge **isn't** the technology—it's the human. **They need** to get **Dave** to click, **and they** know that in 2026, **the best** way to bypass your security **is to bypass** your perimeter entirely."

Slide 5: Phase 1: The Lure & The Mobile Pivot (7:00)

"**We have** to stop thinking **about** suspicious emails on corporate desktops **and start** talking about the move to the pocket."

26:00 – 27:30 | The Path of Least Resistance

"**We have** the engine, **we have** the bouncer—**now** we need the victim. **Attackers** aren't stupid; **they aren't** going to bang their heads against your **corporate** laptop's EDR, **DNS filtering**, and secure gateways. **Instead**, they pivot to the unmanaged **mobile device**. They want to move the fight **from** a ring where you have a referee **to a** back alley where you're blind. **They** are hunting for the 'Pocket Pivot.'"

27:30 – 30:00 | The Black Box of Quishing (QR Phishing)

"**Enter Quishing**. A **QR code** is a total 'black box' **to your** email security gateway. **Most filters** just see an image. **But for** the user, **it's a** call to action. **When Dave** scans a code in a PDF **or on** a breakroom poster, **he's** just bypassed your entire **defensive** stack. **He's on** his personal iPhone now. **There is** no EDR there. **There is** no corporate VPN. **And on** that cramped mobile screen, **the UI** hides the malicious URL. **We've allowed** the attacker to move the battle **to a** device where the 'Padlock' **is the** only thing the user sees, **and as** we know, the **padlock is a lie**."

30:00 – 33:00 | Trust Laundering & AI Context

"**They aren't** using **bad-site.com**. **They use** Open Redirects on domains you trust—**LinkedIn**, Google, or Microsoft. **Your filter** sees 'LinkedIn' and

gives it a green light. **The user** sees 'LinkedIn' **and feels** safe. **But after** the click, **that trusted** domain silently 'launders' the link **through** three hops **until they** land at the proxy.

[Tone shift: Serious] And with LLMs, the 'Cringe Factor' is gone. **They** aren't sending generic spam. **They've** scraped Dave's LinkedIn **and his** company's public contracts. **The lure** says: '*Hey Dave, I'm finalizing that Harrisburg assessment—can you check these permissions?*' **It's not** a phish; **it's a** high-fidelity impersonation. **We're asking** users to **doubt** their **own boss**, and **in a** high-pressure morning, **that is** a losing bet."

33:00 - 33:30 Transition to slide 6

"**Dave is** now looking at an email that sounds **like** his boss, **referencing** a project he's actually working on, **delivered to** a device he trusts. **The psychological** bridge has been crossed. **He's scanning** the code. **He's clicking** the link."

[Click to Slide 6]

"**At this** exact moment, **the** 'Invisible Valet' steps out **of the** shadows. **We're** about to watch the actual theft **happen** in real-time. **This is** the Phase 2 'Capture Dance.'"

Slide 6: Phase 2: The Capture & The Protocol Dance (7:00)

33:30 – 35:30 | The Synchronized Handshake

"The user is on the site. **They've scanned** the code. **To them**, it looks like a normal Tuesday. **But behind** the scenes, **we're** performing the '**Capture Dance**.' As Dave types his username, **the proxy** mirrors those keystrokes **to the** real Microsoft server in milliseconds. **This is** a real-time, synchronized handshake. **When** Microsoft issues the MFA challenge, **the proxy** just passes it through to Dave's phone. **Dave taps** 'Approve,' thinking he's logging in. **He didn't** just authorize himself; **he authorized** the Valet."

35:30 – 38:00 | Plucking the Golden Ticket

"Because our proxy is the TLS Termination Point, **it has** a front-row seat. **Once** that MFA is cleared, **Microsoft** sends back the prize: **the session** cookies. **The proxy** plucks the **ESTSAUTHPERSISTENT** cookie **out of** the HTTP header **before it** ever reaches Dave. **This is** the '**Golden Ticket**.' **It's the** proof that the password **and the** MFA were successful. **The proxy** doesn't need to 'crack' anything; **it just** catches the ball that Microsoft threw."

38:00 – 40:00 | The Clean Hand-off

"To keep the illusion alive, **the proxy** performs a '**Transparent Hand-off**.' **It forwards** Dave to the real SharePoint file. **Dave thinks**, 'That was a weird login,' **but he's** in. **He goes** to his meeting. **Meanwhile**, on the attacker's dashboard, **a notification** pings. **They don't** have a password—they **have** a fully functional clone of Dave's identity. **And here** is the scary part: **Dave can** change his password ten times today, **and the** attacker is *still* in the driver's seat. **Let's talk** about why."

40:00 - 40:30 | Transition to slide 7

"Dave is now looking at his SharePoint file. **He's** productive, **he's** happy, **and he** thinks he's safe. **But back** on the attacker's dashboard, **the 'Golden**

Ticket' has been cashed. **Now**, most of us assume **that once** we catch this, **we just** change Dave's password **and the** threat is gone."

[Step toward the center of the stage. Shake your head slightly.]

"**In the** modern cloud, **that is** a dangerous assumption. **Let's talk** about why the 'Kill Switch' **you've** been relying on might actually be broken."

Slide 7: Post-Compromise: The Persistence Phase (7:00)

40:30 – 43:00 | The Password Reset Myth

"**We have** to stop the lie that a password reset is a 'Kill Switch.' **In 2026**, **session tokens are decoupled from the password**. If you **reset Dave's** password **at 10:00 AM**, but you don't explicitly **'Revoke All Sessions,'** the **attacker** is still in. **The stolen** 'Golden Ticket' **doesn't** check the password database **every time** it's used. **It only** checks its own expiration date. **The attacker** is 'teleporting' that cookie **into a** clean browser globally **while you're** patting yourself on the back **for a** 'successful' password reset."

43:30 – 47:30 | The 60-Minute Breach Window

"**The damage** happens in the first ten minutes. **The attacker** isn't just reading emails; **they are** establishing **Persistence**. They register their own **secondary** MFA device **so they** have a 'legitimate' **way back** in later. **They authorize** a malicious 'Enterprise App' **via** OAuth. **Even if** you kill Dave's session, **that app** still has a persistent API **connection** to his mailbox. **They've** moved from 'Infiltrator' to 'Resident.'"

47:30 – 48:00 | Bypassing Conditional Access

"**Because the** attacker is using a **session** that *already passed* the MFA check, **they are** often invisible to your **Conditional Access** rules. **To your**

logs, **this doesn't** look like a new login from Sweden; **it looks** like a **continued** session from a trusted user **who just** happened to **move IPs**. **The Valet** has moved the car, **changed** the plates, **and is** now part of the fleet. **So, if** the password isn't the shield, **what** is? **Let's look** at the math **that actually** breaks the mirror."

"I've seen IR teams spend 48 hours **chasing** their tails because **they reset** the password, **changed the** MFA, and the attacker *still* sent an email **from the** CEO's account **ten minutes** later. It feels like a 'Ghost in the Machine.' **It's** not. **It's a** stale session. **We have** to break the habit of thinking **the** 'Password' is the soul of the account. **In the** cloud, **the Session** is the soul. **If you** don't kill the session, **you haven't** evicted the tenant."

[At the end of Slide 7, after explaining CAE and CA Bypass]

"It's a grim picture. **We have** an attacker who can teleport cookies, **bypass** passwords, **and hide** in plain sight **for weeks**. If **you feel** like the game is rigged, **it's because**—with our current protocols—it is."

[Tone shift: Pivot to 'The Hero' energy. Click to Slide 8]

Slide 8: The Ultimate Defense: FIDO2 & Origin Binding (7:00)

"But we aren't here to just admire the problem. **We're here** to break the cycle. **It's time** to move away from '**secrets**' and toward the only thing that **can actually** shatter the adversary's mirror."

0:00 – 2:00 | The Mirror Shatterer

"**If you** take one thing home, **let it** be this: **FIDO2** isn't just 'stronger MFA.' **It changes** the physics of the login. **It is** the '**Mirror Shatterer**.' We have to stop **asking** users to be human firewalls **and start** letting the math do the work."

2:00 – 5:00 | Asymmetric Cryptography & Origin Binding

"**Every attack** today works **because** a 'secret'—a **password** or a **cookie**—is sent across the wire. **If it's** sent, **it can** be stolen. FIDO2 uses **Asymmetric**

Cryptography. Your **private key** never leaves the **secure chip** on your hardware. **It's never** sent to the server. **But the** 'Silver Bullet' is **Origin Binding**. When **you tap** that key, **the browser** tells the key: **'Sign this** for **microsoft.com.'** **If you're** on the proxy's **microsoft-security.com**, **the browser** sees the difference. **It tells** the key the wrong name."

5:00 – 7:00 | The Cryptographic Refusal

"**The hardware** key looks at its storage, **sees that** it has no credentials **for** the attacker's fake domain, **and it physically refuses to sign**. No **'Proceed** anyway' button. **No user** error. **The 'Invisible Valet'** can relay the **request** all day, **but he** cannot forge the signature. **You've moved** the burden of **security** from Dave's tired eyes **to the** computer's unyielding math. **We've secured** the 'Front Door.' **Now, let's** lock the session to the machine."

[At the end of Slide 8, after explaining the Cryptographic Refusal]

"**So, FIDO2** is our shield for the 'Front Door.' **It ensures** the login itself is unphishable. **But as** security engineers, **we know** that 'Identity' doesn't end at the login. **It lives** in the session. **Even with** FIDO2 at the door, **we still** have **millions of** active cookies **floating** around our environments **every day**."

[Click to Slide 9]

Slide 9: Defensive Architecture: Token Protection (7:00)

"**We need** a way to **make sure** those cookies **are just** as unphishable **as** the login. **We need** to anchor **that digital** identity **into the** physical silicon of the machine."

0:00 – 3:00 | Locking the Cookie to the Silicon (DBSC)

"**We've seen** how easy it is to 'teleport' a cookie. **But through Device Bound Session Credentials (DBSC), we are** turning that cookie **into a** 'Digital Brick' **the second** it leaves the laptop. **The browser** creates a key

pair inside the **TPM 2.0 chip** on the motherboard. **The session** cookie is now **cryptographically** tied to that specific silicon. **If our** Valet steals that cookie **and tries** to inject it into a browser **in another** country, it fails. **Why? Because** the attacker's laptop **doesn't** have the private key **burned** into **Dave's** hardware."

3:00 – 5:00 | The Heartbeat Check & CAE

"**This isn't** a one-time check. **The server** now performs a '**Heartbeat**' challenge. Every **few minutes**, it asks: '**Do you** still have that TPM key?' **If the** proxy can't sign—which it can't—the **session** dies. **Pair this** with **Continuous Access Evaluation (CAE)**. Traditional security **only checks** at login. **CAE is** a security guard **that** follows Dave around. **If the** system **sees** an 'Impossible Travel' alert, **CAE** kills the session **globally in under 60 seconds**. **We aren't** waiting for a timeout anymore; **we're** reacting at the speed of light."

5:00 – 7:00 | The "Day 1" Reality

"**We've** dismantled the engine, **we've** looked at the bouncer, **and** we've built the shield. **Now**, it's time to go home. **Let's** talk about your Day 1 Plan."

[At the end of Slide 9, after explaining Continuous Access Evaluation]

"**We've gone** from the engine room of the proxy **to the** secure enclave of **the TPM** chip. **We've** looked at how the 'Invisible Valet' **operates** and, more importantly, **exactly how** to stop him. **Insight** is the start of the **conversation**; **execution** is the end of the threat.

[Take a deep breath. Look at the audience.]

"**You're heading** back to your offices on Monday morning. **The watering** holes aren't going anywhere. **So, let's** talk about exactly **what you're** going to do **when you** get there."

Slide 10: Conclusion & Your Day 1 Plan (5:00)

0:00 – 2:00 | Architecture Over Awareness

"We cannot train our way out of a protocol failure. **Stop blaming** Dave. **Stop** asking your engineers to be protocol analysts. **Architecture is the answer.** You have the blueprints now. **You know** how they get in, **and you** know how to lock them out."

2:00 – 4:00 | The Monday Checklist

"Monday morning, do three things:

- 1. Audit your Admins.** If your Global Admins aren't using FIDO2 keys, **the door** is open.
- 2. Update your IR Playbook.** Step 1 is no longer 'Reset Password.' **Step 1** is **'Revoke All Sessions.'** Kill **the tokens**, *then* **change the** password.
- 3. Deploy Token Protection.** Use the TPM chips you already **paid for**. **Bind** your identity to your hardware."

4:00 – 5:00 | Final Word

"The 'Same Watering Holes'—SharePoint, Teams, Outlook—are **still** there. **But today**, you know how to drain them. **Thank you**, BSides Harrisburg. My name is Joel Prentice, and I'll be at the back for questions."